

外部廠商開發與佈署技術規範說明書

版本	日期	狀態	說明
v1.0	2026-04-29	發佈	

1. 文件目的與適用範圍

本規範定義外部廠商於開發、測試至佈署階段應遵循的技術準則，確保系統品質、安全性與可維運性。

適用於部署至 **Google Cloud Platform (GCP)** 的所有系統開發、API 設計、部署與維運相關作業。

部署優先順序：本公司優先採用雲端環境。如專案需使用地端環境，請參閱《外部廠商開發與佈署技術規範說明書（地端版）》。

文件部分章節內容為參考方向，實際細節將於開發啟動會議（Kick-off）中確認。如有疑問、需調整或本文件未提及之事項，可於開發啟動會議中另行補充或協議。

2. 指定技術棧 (Tech Stack)

層級	技術	版本要求	構建工具
後端	Java + Spring Boot	Java 17 (LTS)+、Spring Boot 3.0+	Maven
前端	Angular (TypeScript)	Angular 18+	npm
API	RESTful API	—	—
版本控管	Bitbucket	—	—
雲平台	GCP (GKE)	—	—
資料庫	MySQL / MongoDB	—	—
身份驗證	Keycloak	—	—
CI/CD	GCP Cloud Build	—	—

代碼品質：後端須遵循 Google Java Style Guide；前端須啟用 Production Build。

3. 系統設計規範

- 採用**微服務架構（Microservices）**或**模組化單體（Modular Monolith）**。
- 所有服務須：
 - 可獨立部署
 - 可水平擴展（Horizontal Scaling）

- 無狀態 (Stateless)

4. 版本控管與 Git 工作流

統一平台：Bitbucket。開發啟動前，廠商須提供開發人員 Email 帳號以申請倉庫及 GCP 相關權限。

分支策略：

分支	用途	合併限制
feature/*	功能開發	合併至 develop
develop	開發環境 (Dev)	自由合併
qa	測試環境 (Staging)	須經我方審核
main	正式環境 (Production)	嚴格管控，僅限發佈

5. API 設計規範

- API 須符合 RESTful 標準。
- API 須回傳統一格式，例如：`code`、`message`、`data`、`timestamp`。

```
{
  "code": "0000",
  "message": "success",
  "data": {},
  "timestamp": ""
}
```

- 須實作全域異常攔截機制。
- 須提供 **Swagger / OpenAPI 3.0** 文件。
- 建議實作 **API Versioning**（路徑格式：`/api/v1/`）。
- 建議設定 **API Rate Limit**，防止濫用。

6. 前端開發規範 (Angular v18 以上)

- 需符合 Angular 官方風格指南。
- 模組化設計 (Core / Shared / Feature modules)。
- 必須使用：
 - ESLint
 - Prettier

- 必須具備單元測試（Coverage $\geq$ 80%）。
 - UI/UX 必須支援 RWD 及跨瀏覽器（Chrome / Edge）。
-

7. 後端開發規範（Spring Boot v3.0 以上）

7.1 架構分層（建議）

採用分層架構：Controller → Service → Repository

7.2 安全性

- 必須整合 **Keycloak OAuth 2.0 / OpenID Connect** 進行身份驗證。
- API 必須驗證 **JWT Token**。
- 應用程式須配合 Keycloak 實作 OIDC 流程以取得使用者權杖 (Token)。

7.3 日誌規範

- 使用統一 logging framework（如 Logback）。
- 必須記錄：request / response、error message。

7.4 稽核日誌（Audit Log）

後台管理功能必須紀錄操作者、時間、變更前後數值及來源 IP。

8. 資料庫規範

8.1 MySQL

- 需正規化設計（至少 3NF）。
- 使用 index 優化查詢效能。
- 禁止使用 **SELECT ***。
- 資料庫腳本須支援重複執行而不報錯（Idempotency），並包含 Schema 建置及初始資料。

8.2 MongoDB

- 需定義 Schema（不可完全自由格式）。
 - 使用場景需明確（如：log、文件資料）。
-

9. 資料安全與 Secret 管理

- 所有傳輸須使用 **HTTPS**。
- 敏感資料須加密（**傳輸層**）。
- 須符合 **OWASP Top 10** 防護標準。
- 建議設定 **API Rate Limit**，防止濫用。
- **Secret 管理**：敏感資訊（API Key、密碼、憑證）嚴禁寫死於程式碼中，建議以環境變數管理。

10. CI/CD 規範

▢ 內容參考：以下流程為參考方向，實際工具選型與各階段細節將於 Kick-off 會議中確認。如有疑問或需調整，請於會議中提出。

廠商提交代碼至 Bitbucket 後，**GCP Cloud Build** 將自動執行以下流程：

```
Commit → Build → Docker Build → Deploy → GKE
```

各階段說明：

1. **Build**：根據 **Dockerfile** 封裝映像檔。
2. **Docker Build**：建置並推送映像檔至私有 Artifact Registry。
3. **Deploy**：更新 GKE Deployment 之映像檔版本。

廠商須確保 **Dockerfile** 及相關配置文件正確，以利 Cloud Build 正常執行。

11. 容器與部署規範（Docker / GKE）

11.1 Docker

- 必須提供 **Dockerfile**。
- Image 必須：
 - 精簡（建議使用 Alpine base）
 - 不得含敏感資訊

11.2 Kubernetes (GKE)

- 必須提供以下 YAML 資源定義：
 - **Deployment**
 - **Service**
 - **ConfigMap / Secret**

- 高可用要求：
 - 至少 2 replicas
 - 設定 readinessProbe 及 livenessProbe

12. 測試與資安掃描要求

- 掃描工具：交付前須通過 SonarQube 或同等級原碼掃描工具。
- 修復標準：Critical / High 等級弱點須全數修復；Medium 以下依專案協議處理。
- 報告提交：驗收時須隨附掃描報告及修復證明。

13. 階段交付物要求

13.1 開發啟動前 (Pre-Development)

交付項目	說明	負責方
設計文件	架構設計書、ERD 設計圖、系統架構圖	廠商提供
API 規格	OpenAPI 3.0 文件	廠商提供
人員申請	開發人員權限申請表（含 Google 帳號）	廠商提供
資源清單	技術資源需求清單（CPU / Memory / 環境變數名稱）	廠商提供

13.2 開發過程中 (During Development)

交付項目	說明	負責方
原始碼	Bitbucket 代碼紀錄	廠商維護
配置文件	pom.xml、package-lock.json、Dockerfile	廠商提供

13.3 驗收交付時 (Handover)

交付項目	說明	負責方
最終產出	main 分支代碼、Container Image、Kubernetes YAML	廠商提供
資安報告	SonarQube 掃描報告、單元測試報告（涵蓋率 ≥ 80%）	廠商提供
技術文檔	系統架構圖、API 文件、DB Schema 文件、GCP/GKE 部署文件、操作手冊、環境變數對照表、稽核日誌實作證明	廠商提供

14. 驗收標準

4. 符合技術棧規範（Java 17+ / Maven、Angular 18+ / npm、Spring Boot 3.0+）。
5. 通過資安掃描，Critical / High 弱點全數修復。
6. 具備完整的 Audit Log 紀錄。
7. 所有敏感資訊均已環境變數化。
8. **API response time < 2 秒**。
9. **系統可用率 ≥ 99.5%**。
10. **測試覆蓋率 ≥ 80%**。
11. 無高風險資安漏洞。

驗收未通過項目，廠商須於協議工作天內完成修正並重新提交。

15. 聯絡窗口與溝通機制

事項	聯絡方式
技術問題	請聯繫專案技術負責人（Kick-off 時確認）
權限申請	請聯繫專案管理負責人
規範疑問	於 Kick-off 會議提出，或以書面方式確認

附件 A：開發人員權限申請表

姓名	角色	Google 帳號 (Email)	權限需求說明
----	----	-------------------	--------

權限將於專案驗收完成後 7 天自動關閉。